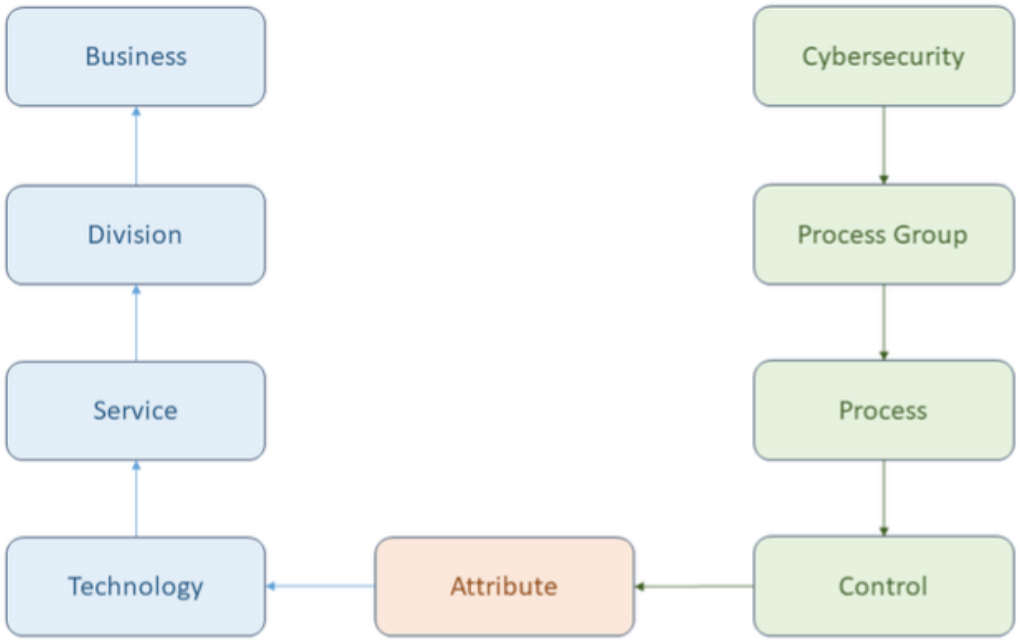
User Guide: Cybersecurity Management and Performance Assessment (CSMPA)

Introduction

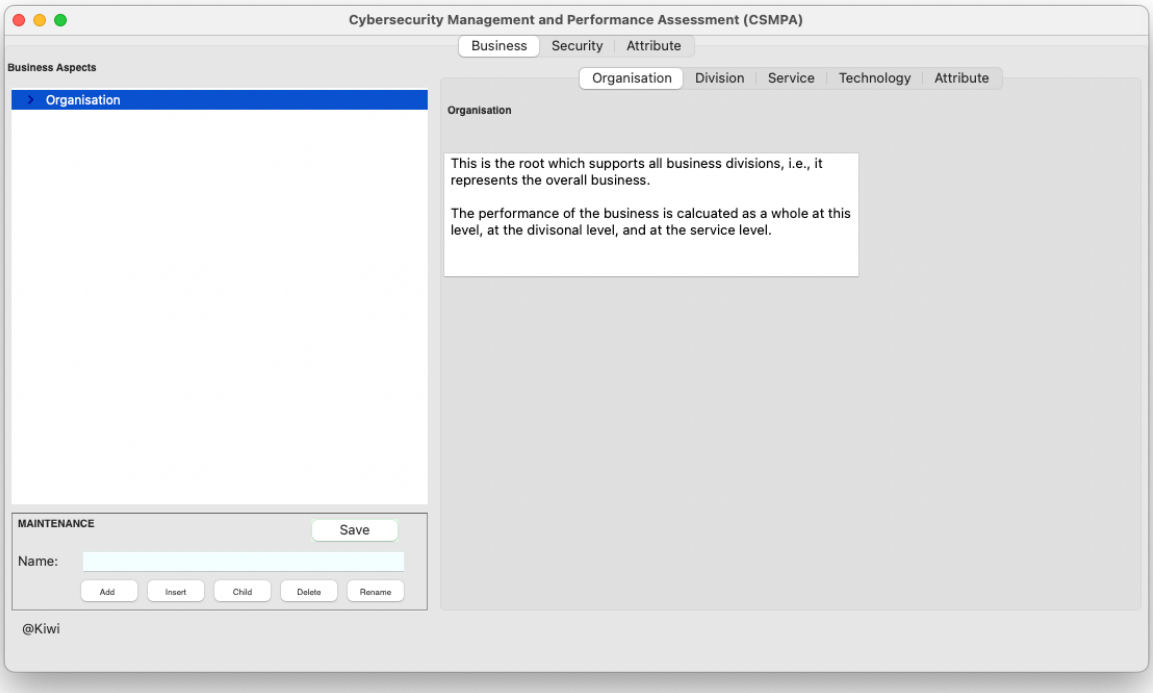
The CSMPA package has been developed to support the assessment of how effective cybersecurity management is for a business. The package is driven by a first-order model of the business, represented as business divisions and the services they provide, which directly or indirectly deliver value to the business. The cybersecurity activity is modelled as a set of strategic, tactical, and operational processes that result in cybersecurity controls supporting the technology used in the business services. The two sides of the model are shown below, linked by a concept known as *attributes*.



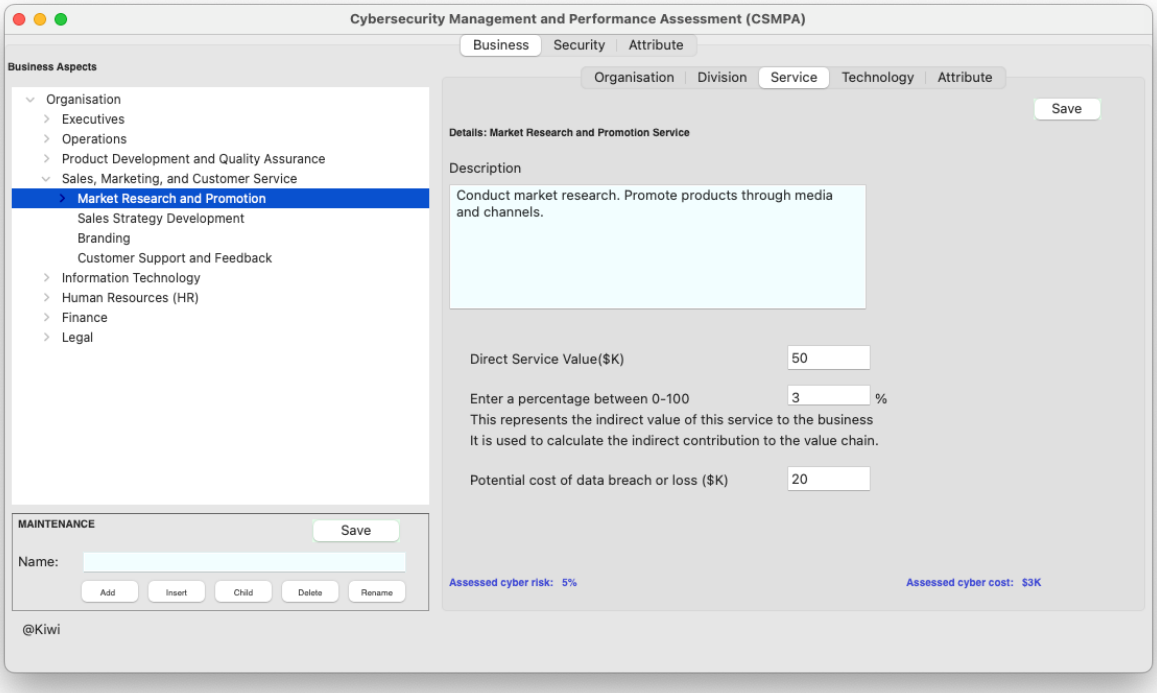
Attributes represent the atomic elements of security required to ensure business outcomes are delivered, according to the SABSA Enterprise Security Architecture framework (Sherwood et al., 2005). They provide a common language through which the business can request security services, and the cybersecurity team can deliver them. In our model, the delivery of cybersecurity into the technology, and the effectiveness of that technology in supporting business services, is represented using SABSA attributes.

User Interface

The CSMPA package is a GUI application that runs as a Python script, supported by an internally managed SQLite3 database. The main GUI screen is as shown below.



The interface is in two parts: on the left a tree-structured view of the Business, Security, and Attribute elements; and a Details panel on the right. The panel at the right is activated when an element of the tree is selected, as follows.



Each of the right-hand Details panels has a *Save* button, which is used to save any changes made in the panel.

Similarly, the tree structures all have a Save button at the bottom, which is used to save the active tree after any changes have been made.

Business Viewpoint

Business Tree

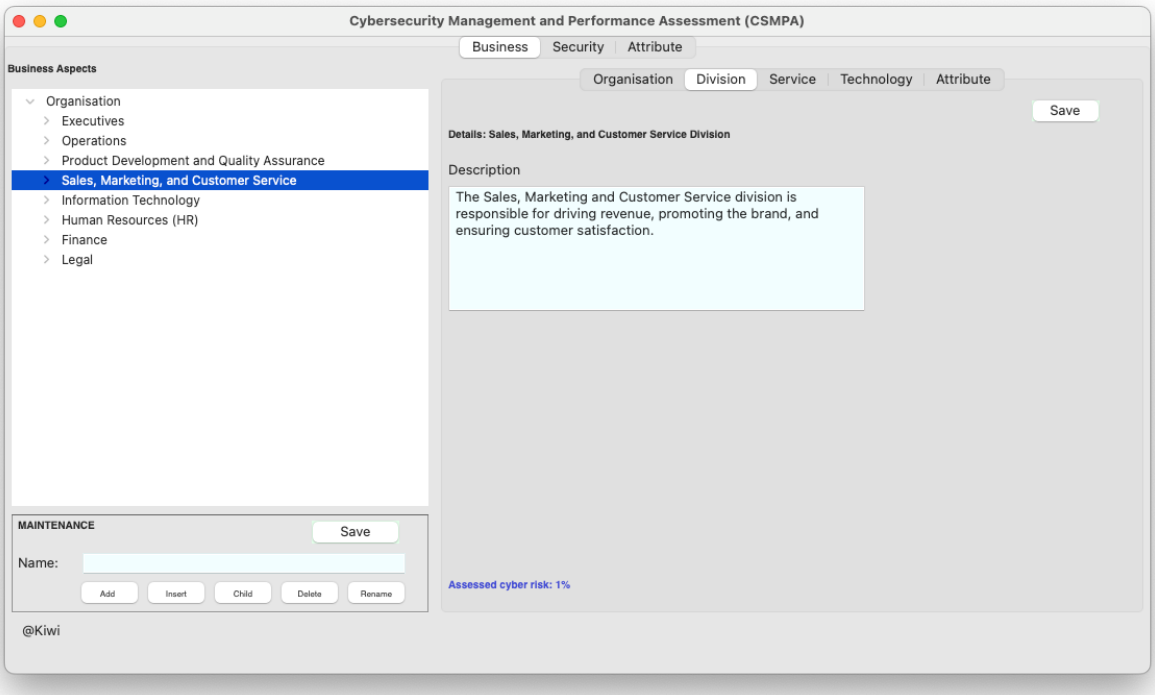
The left-hand *Business* tab provides the business viewpoint. After clicking it and expanding the top level *Organization* item, there are a series of business divisions. New divisions can be added by entering the division name in the textbox below the left-hand panel and selecting *Child*. This creates a division which is a child of the root item. Alternatively, select an existing division in the textbox, and press *Add* to add an entry at the same level below the currently selected item. The entry can be added above the currently selected item by clicking *Insert*.

The *Delete* button will delete the currently selected entry. If you want to change the name of an item in the tree, double click it to have the item's name placed into the textbox, change it, and click *Rename*.

Don't forget, these changes won't be saved automatically. If you make changes and then quit, they will be lost. To save them, press the *Save* button located below the left-hand panel.

Note that while the right-hand panel tabs can be activated manually, only the page selected in the tree will be active; all others will be disabled.

Business Division



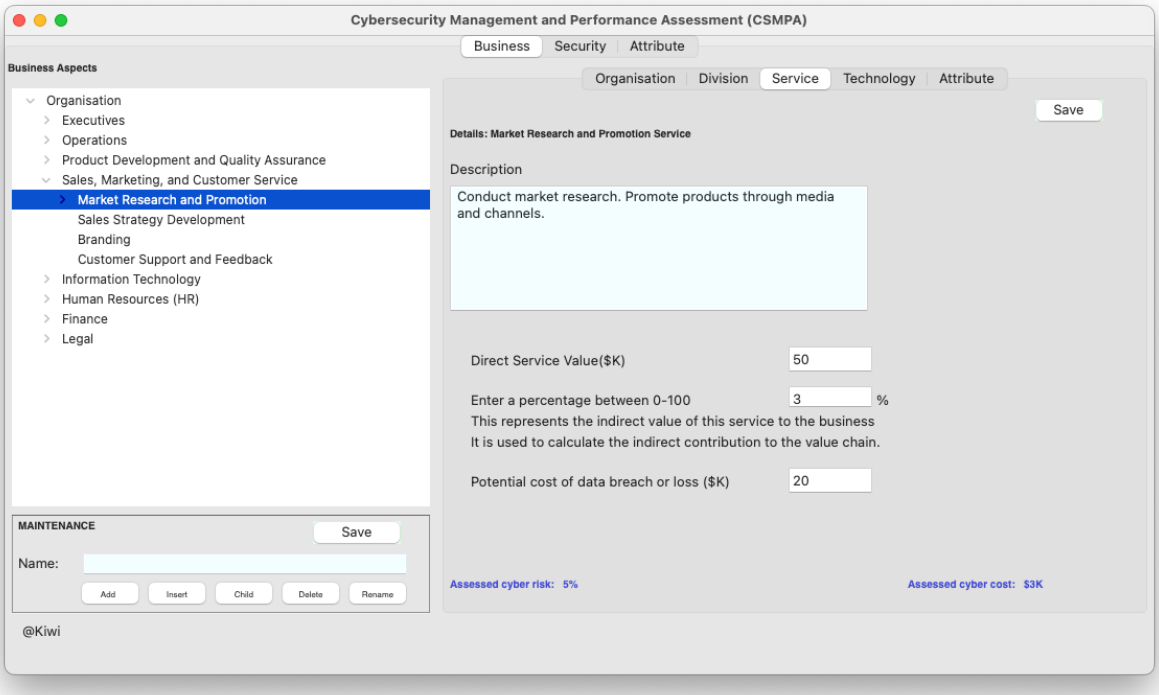
By expanding the top-level *Organization* root, the Divisions will be shown. From above, we see an entry for **Sales, Marketing, and Customer Service** with a brief description and, at the bottom, the assessed cyber risks of this Division.

The *Description* can be changed to reflect the Division activities and saved by clicking *Save*.

A new division can be added by entering its name in the textbox below the left-hand panel and pressing *Add* to add it after the current selection or *Insert* to add it before the current selection. The new entry will have a blank description, this can be added and saved as required.

Divisional Service

A business division consists of a set of services that either directly (through revenue) or indirectly (through support to revenue-generating divisions) support the goals and objectives of the division. By expanding a division entry in the left-hand panel, all the services provided by that division are shown, as follows.



The *service* is the key business element in the model, as this is where we represent the value of the business by using the following three fields.

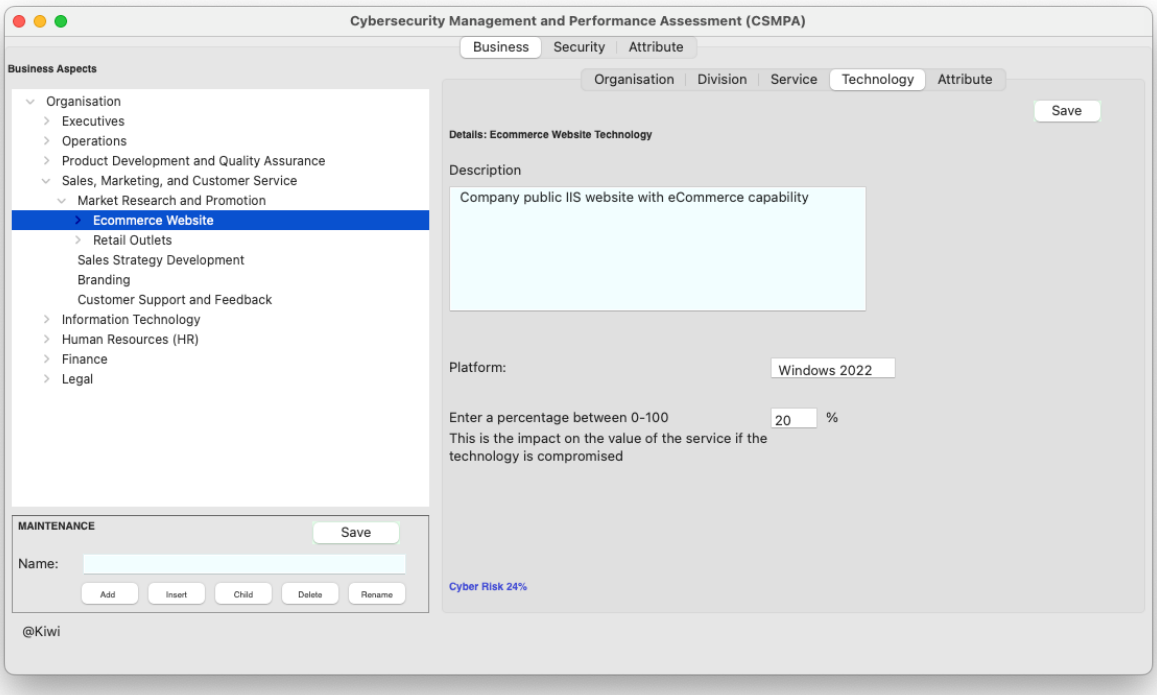
- **Direct Service Value**. The direct service value is the revenue that is gained for the business by running this service. The service can be as granular as we like, but as a rule of thumb the services that use the same technology can be aggregated into a single service line as that is the level of granularity of the risk calculations.
- **% enabling the business**. There are many services which do not result in direct value. These include internal services such as *Finance*, *Logistics*, and *Compliance* activities. In either case, there is a cost of not doing them which we represent as an overall % reduction in the performance of the business.
- **Potential cost of data breach or loss**. The cost of a failure of the underlying technology for a service is represented as a reduction in the revenue earned by the service. In addition to this, there is the potential for data breach and the attendant costs of remediation, which will be related to the kind and amount of data stored, or the loss of data through destruction of ransomware. While not affecting the service itself, these events will have associated direct costs. The costs of such events are represented separately as the potential cost of a data breach.

To add a service to a division, enter the service name in the textbox below the left-hand panel. If you have the division selected, press *Child* to add it to the next level down. If you have the service selected, add a new one by clicking either *Insert* or *Add*.

The right-hand panel contains a service description. This is blank for a new service and can be added as required. At the bottom, the assessed cyber risk to the service is shown, based on the cyber risk to the technologies used in that service. The cost of this is assessed as the risk percentage applied to the service revenue and the data breach/loss value. This is shown as the *Assessed cyber cost*. The cyber risk is also applied to a reduction in the overall business value calculated as the % enabling the business multiplied by the risk factor.

Technology

Each service can be expanded to show the technology used to support that service. The cybersecurity program provides controls which protect the technologies used to run services. These may be revenue generating services, or they may be internal support services.



In the example above, we have an ecommerce website which is used to deliver direct product information to customers and also to support channel sales. The right hand panel has a description of the technology and an informative reference to the platform being used.

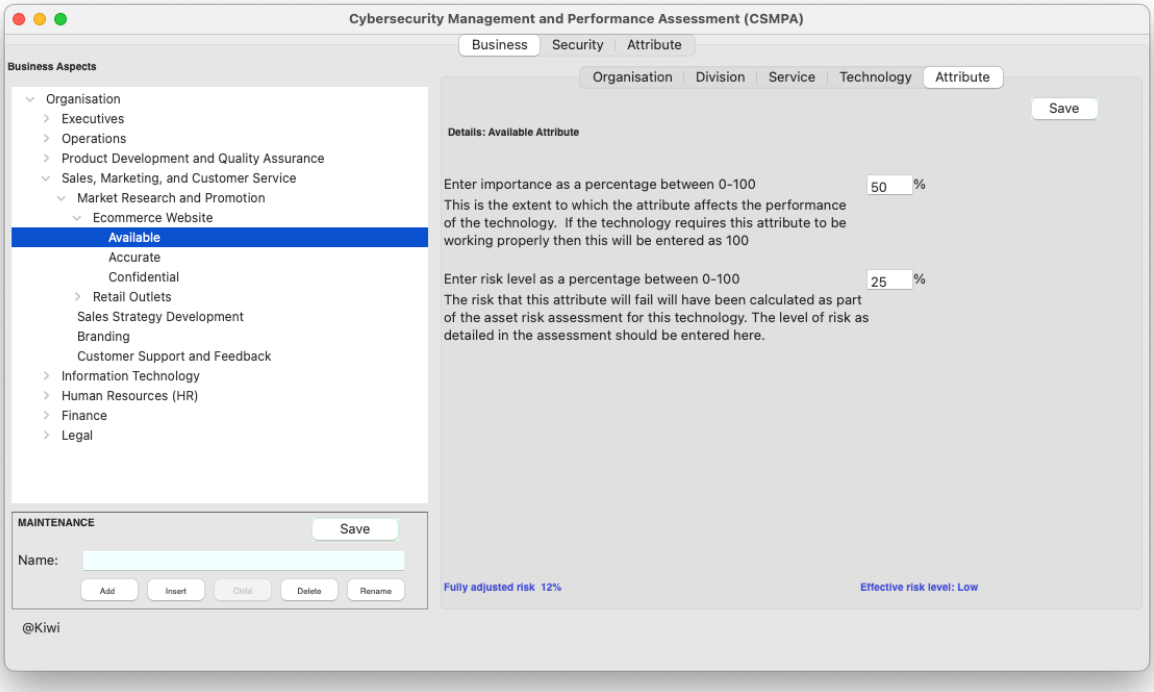
We represent the importance of the technology to the service as a percentage, indicating the loss of service value that would occur should the supporting technology be disrupted. In this example, we're indicating that there would be a 20% loss of revenue from the service in a cyberattack.

The risk of a cyberattack being successful is shown in blue at the lower right. This is calculated from the underlying attributes of the technology.

As with the other elements, technologies can be added, change and removed by using the controls below the left-hand pane.

Attribute

According to the SABSA framework for enterprise security architecture, risk to technology is represented as a set of attributes. Attributes can be associated with a technology by adding them as children of the technology, as shown below. Individual attributes may be relatively more of less important in the technology, and this is represented as a percentage which reflects the maximum impact on the technology should that attribute be degraded or fail.

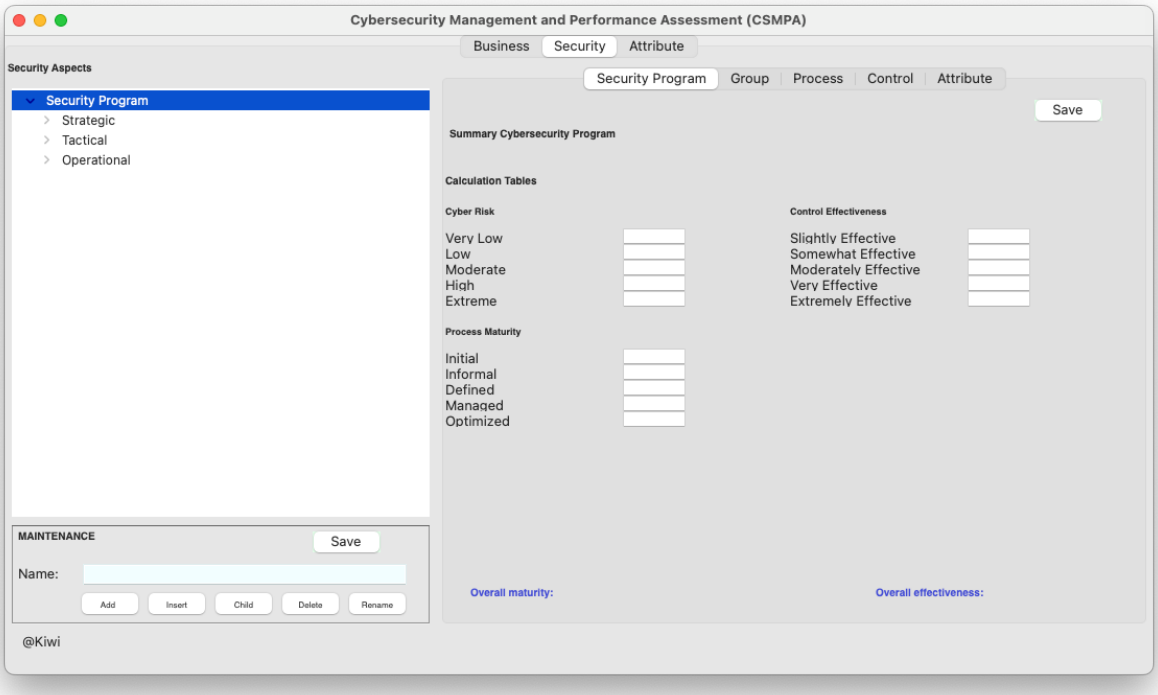


In this example, there are three attributes associated with the eCommerce website, *available, accurate and confidential*. The selected attribute is *available*, with 50% impact on technology effectiveness.

Cybersecurity Viewpoint

Cybersecurity Tree

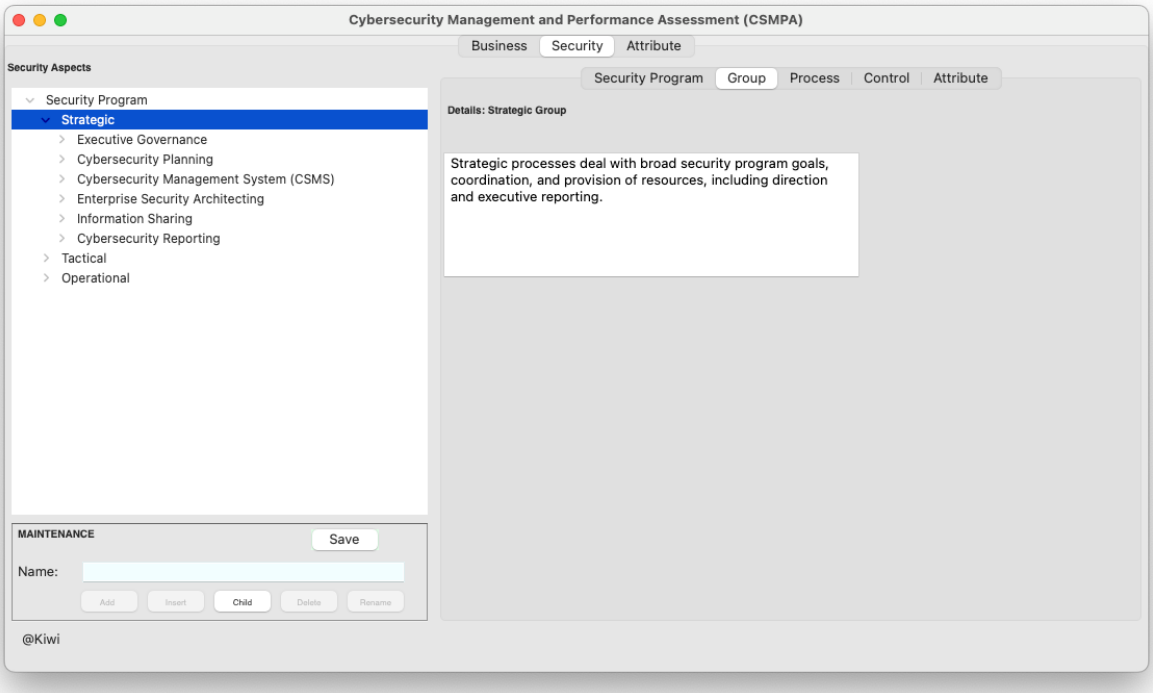
The CSMPA application provides a separate cybersecurity viewpoint. This is where the cybersecurity program is run to deliver security in the form of attributes. This part of the model starts with the cybersecurity program as a whole as shown on the main tree root *Security Program*.



This provides the overall maturity of the cybersecurity program based on the maturity ratings entered on all processes, together with its overall effectiveness based on attribute risk levels.

Security Process Group

The security processes are grouped into the three tiers of *Strategic*, *Tactical* and *Operational*.



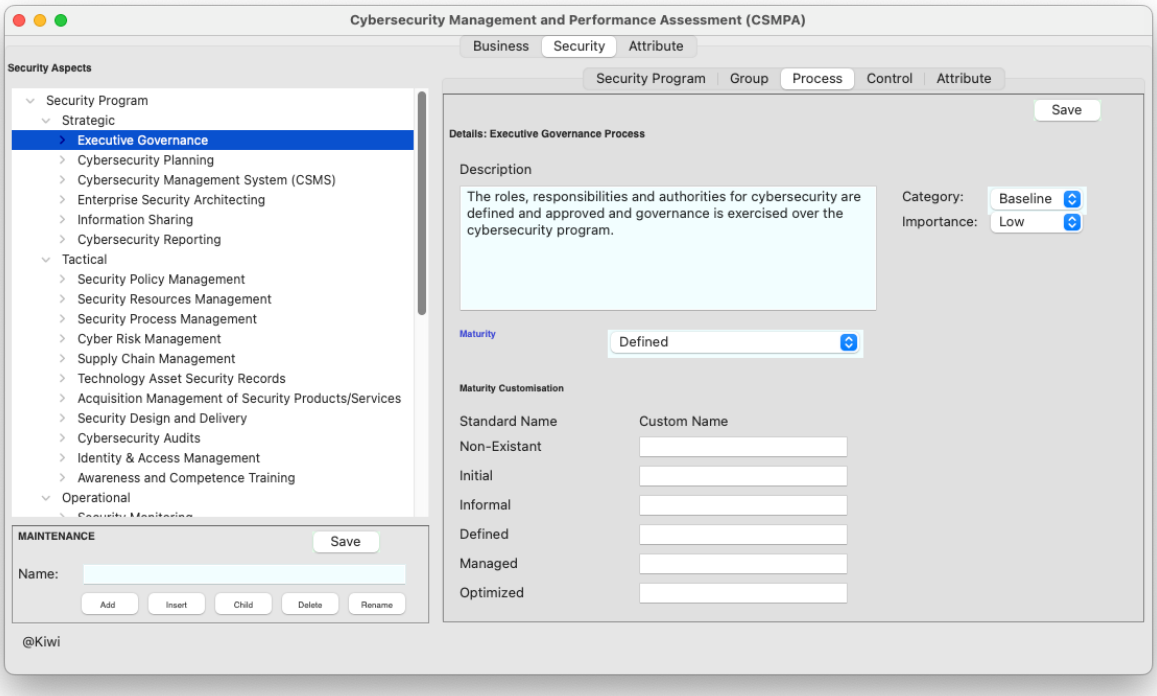
Strategic processes are a set of cybersecurity governance procedures designed to select and deliver security services within acceptable cost and risk parameters (OpenGroup, 2017), such as executive governance, cybersecurity planning.

Tactical processes are security processes aimed at addressing the design and implementation of CSMS and the management of security resources (OpenGroup, 2017), such as supply chain management, cybersecurity audits, awareness and competence training.

Operational processes are routine security processes designed for the defined goals of cybersecurity protection, for example, security monitoring, backup and recovery, system hardening.

Security Process

A cybersecurity program essentially consists of various cybersecurity processes. Our model covers 6 strategic processes, 11 tactical processes, and 19 operational processes as follows.

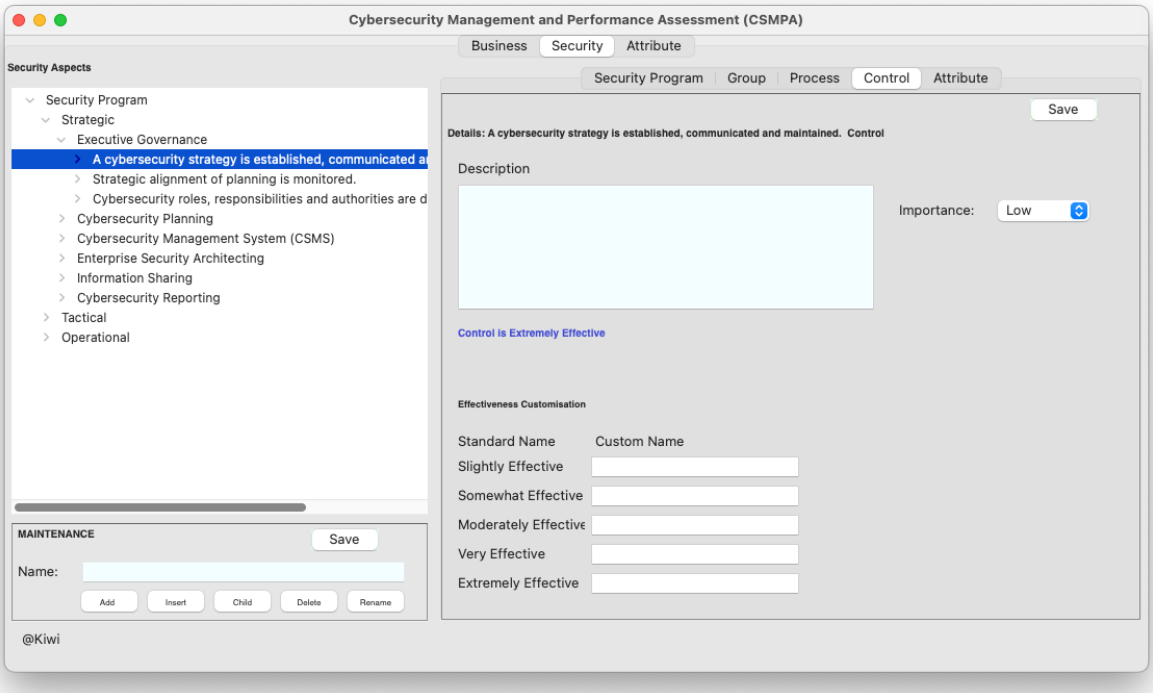


Processes are classified into three categories, baseline, risk-informed, and enhanced. Each process includes a short description, process category, and maturity weight. The weight is designed to reflect the importance of that process, assigned in the initial stage of the assessment.

The user enters the maturity level of the process using the drop-down list. The naming of the different levels of process maturity is customizable.

Security Control

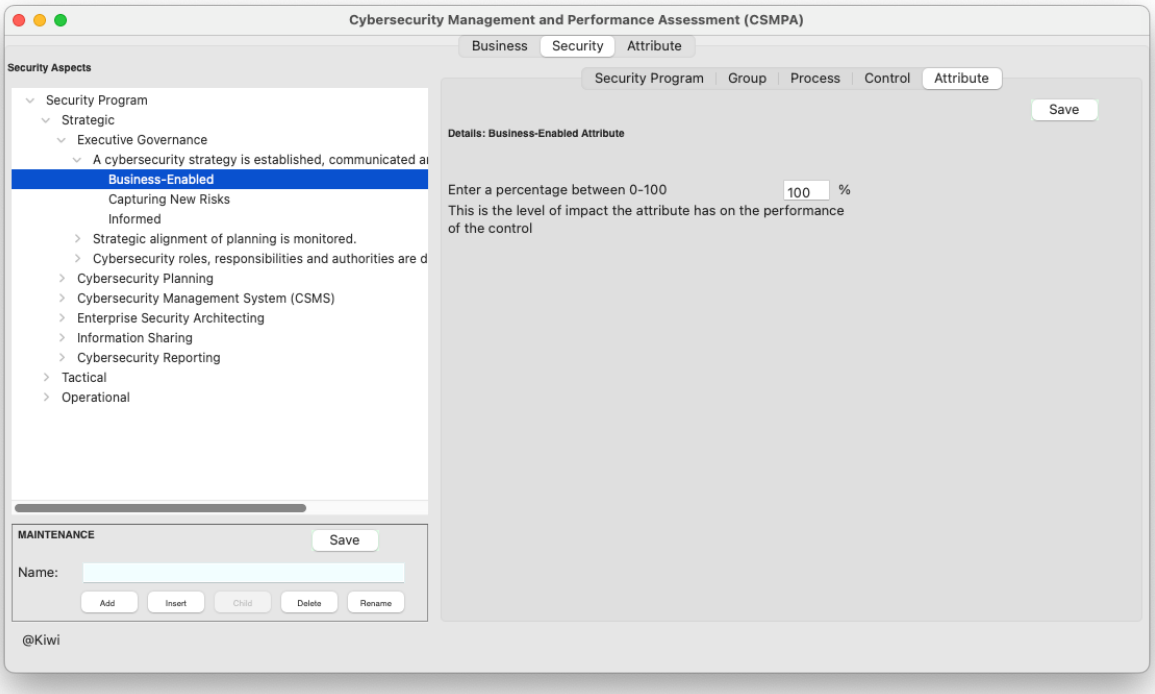
The objective of the cybersecurity processes is to deliver a defensive control for the business to use in the technologies which support their activities. Each security process includes a set of security controls as follows.



The control effectiveness is calculated by aggregating the underlying attribute risk. Similar to maturity, the naming of the different levels of control effectiveness is customizable.

Control Attributes

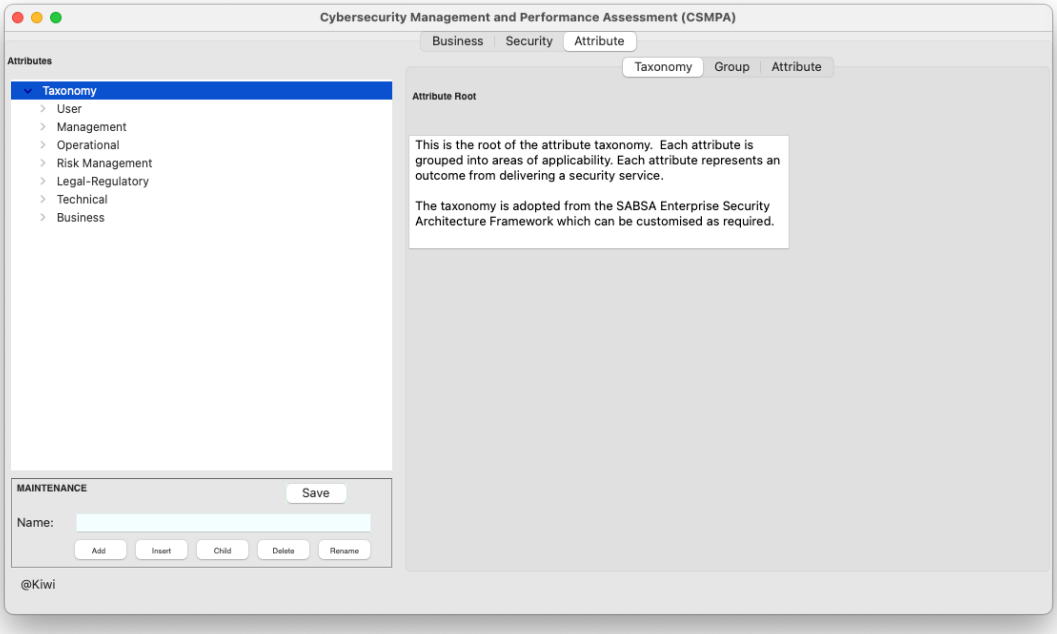
Controls deliver security capability in the form of *security attributes*. These are the security primitives which are applied to technology, such as *availability*, *integrity* and so on. SABSA provides a standard repository of attributes (Sherwood et al., 2005) that users can adopt or define their own.



The above screenshot indicates the impact that the attribute will have on the performance of the control. This is then used when calculating the control risk, which consists of the average of the risks from each of its attributes. As an example, if the attribute has been assessed as having a 10% risk, and the impact on the control is 20%, then the resulting risk contribution at the control level from this attribute would be 2%.

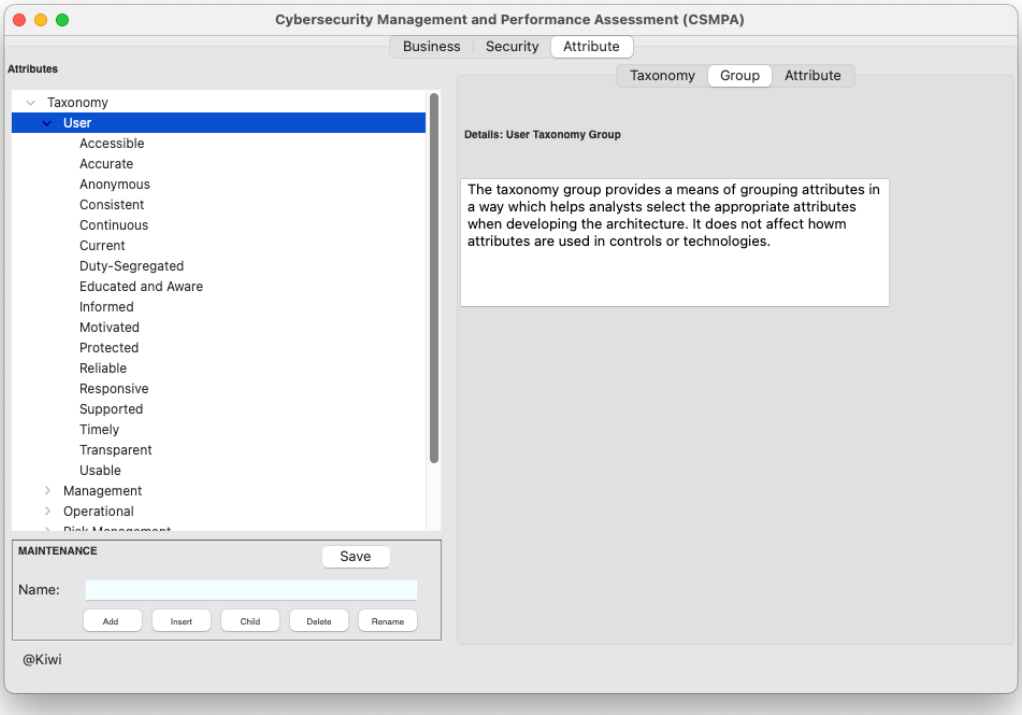
Attribute

The Attribute tab provides a view of the attributes by groups, as shown below.

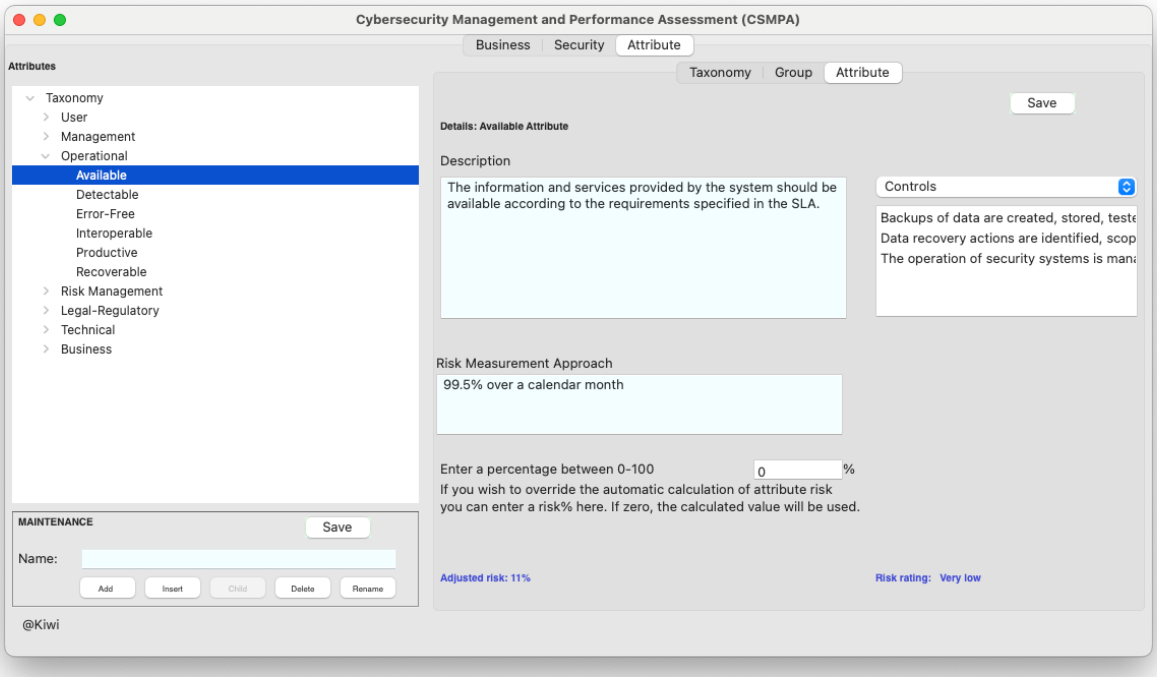


Attribute Group

The classification of predefined security attributes follows SABSA's standard taxonomy including *User*, *Management*, *Operational*, and so on (Sherwood et al., 2005). Users can also customize the classification of the security attributes by using the control panel in the left corner of the screen.



Attribute



Each attribute has to be measurable in terms of risk. As shown in the screenshot above, each attribute has a descriptive field and a risk measure field that illustrates the risk metrics and how the attribute is measured.

In practical terms, the measurement of attribute risk is done in association with the technology it supports, and an attribute will often support multiple technologies. The technology-oriented attribute risk is then used to calculate the overall attribute risk rating as an aggregate across all usage.

Attribute risk is used to calculate its parent control risk. A manual risk override value can be entered if there is reason for the risk used in control risk calculations to be different from the calculated risk. The override field can also be used for attributes which are included but not associated with technology.

Performance Assessment and Risk Calculations

This tool can be used to calculate of the maturity and effectiveness of a cybersecurity program and of all the risk levels. The logic is as follows.

- Calculate the Cybersecurity program maturity by taking the average weighted maturity value across all cybersecurity processes. Then use the factor table to select a risk adjustment factor.

- Update the *Technology* risk by aggregating all the individual technology attribute risk values. These are calculated as the base risk level for the technology attribute, factored by its importance to the technology's performance, and then adjusted by the risk adjustment factor calculated above.
- Update the *Service* risk by aggregating all *Technology* risks associated with the *Service*.
- Update the business *Division* risk by averaging all service risks associated with the *Division*.
- Update the *Attribute* risk as the average of all technology-related risks for that attribute.
- Update the *Control* risk as the average of all *Attribute* risks.
- Update the Cybersecurity program control effectiveness by averaging all control risks across all divisions.

Maturity

The maturity calculation starts with the set of cybersecurity processes. Each process has a maturity level and a weight, both entered by the assessor. The maturity level of a security process ranges from 0 to 5, which we denote as pm. The associated weight, denoted as *pw*, represents the relative importance of this process compared to other processes in the cybersecurity program. The overall maturity of the cybersecurity program, denoted as *maturity*, is then calculated as the weighted average of all processes.

$$maturity = \frac{\sum(pm * pw)}{\sum pw}$$

We assert that at a lower level of maturity, the risk of the controls provided by the process failing is increased, while at a higher level of security the risk is reduced. The percentage by which to increase or decrease control risk is shown in the Maturity and Risk Adjustment table in the Appendix. For example, if the Maturity Level is Informal with a corresponding Risk Adjustment Factor setting of 150%, the risk will be increased by half again (i.e. multiplied by 1.5) to reflect the extent to which the risk of process failure should be factored into control failure for those controls within that process. We select the overall risk increase/reduction factor (denoted as *dr*) from Table 1 in the Appendix based on the maturity level calculated above. We will subsequently use *dr* to adjust our attribute-driven risk that we'll calculate next.

Risk

Technology Risk

Each technology attribute has a *base* risk which is calculated external to the tool. This is denoted by *br* and is adjusted based on the maturity-derived risk adjustment factor *dr* mentioned in the above section.

The technical attribute also has an impact rating set by the assessor, indicating the extent to which the attribute affects the performance of the technology, denoted as *rr*. The overall risk to the technology *tr* is calculated as the sum of all attribute risk.

$$tr = \sum(br * dr * rr)$$

Service Risk

A service consists of business processes supported by technology and people. For each technology used in the service, we record the impact that the loss of the technology would have on the service, which we denote as the delta technology risk *dt*. The overall risk to the service from its underlying technology, denoted as *sr*, is simply the sum of all technology risks *tr* factored by *dt*.

$$sr = \sum(tr * dt)$$

Division Risk

The final calculation of cyber risk occurs at the Division level and is the average of all service effectiveness managed by the Division. We denote this as division risk *gr*, and the number of services in the group is denoted by *ns*.

$$gr = \frac{\sum sr}{ns}$$

Attribute Risk

Different technologies may have their security requirements represented by the same attribute. We denote the number of instances of the attribute as *na*. In order to assess the overall risk of an attribute, which is shown on the attribute record and denoted *ar*, is the average of the per-technology attribute risk.

$$ar = \frac{\sum(br * dr * rr)}{na}$$

The attribute record allows for an assessor to enter a risk level, the risk override, which takes precedence over the calculated risk. The final risk value is then used to select a risk rating from the Effectiveness and Risk table in the Appendix.

Effectiveness

Control Effectiveness

By assessing the level of risk associated with each attribute at the point of risk realization, the technology level, and then deriving overall attribute risk from that, we can reflect back to the control through which we delivered the security attribute the effectiveness of that control which we denote as *ce*. In other words, the control is as effective as the effectiveness of the attributes it delivers.

We provide an impact rating *ir* to allow for each attribute to contribute to a varying extent to the effectiveness of the control as determined by the assessor.

$$ce = 100\ \% - \sum(ar * ir)$$

The calculation is then used to select the appropriate level of effectiveness from the Effectiveness and Risk table in the Appendix.

Overall Effectiveness

The control weight, denoted as *cw*, represents the importance of this control. The overall effectiveness of the cybersecurity program, denoted as *effectiveness*, is the average of the weighted control effectiveness.

$$effectiveness = \frac{\sum(ce * cw)}{\sum cw}$$

Potential Cost Due to Cyber Risk

A service is the point at which revenue occurs, and so each service has an assessed service value *sv*. Should an event occur which results in a data breach for this service, the cost of data breach is denoted by *bv*. We can calculate the potential cost of cyber risk, *sc*, as follows

$$sc = sr * (sv + bv)$$

References

OpenGroup, 2017. *Open Information Security Management Maturity Model (O-ISM3), Version 2.0*. https://publications.opengroup.org/c17b?_ga=2.99004061.2002443395.1671458540-17608643.1670157460.

Sherwood, J., Clark, A., & Lynas, D., 2005. *Enterprise security architecture : a business-driven approach* [Online]. CRC Press.

Appendix

Table 1 Maturity and Risk Adjustment

Maturity	Risk Adjustment
Initial	200%
Informal	150%
Defined	100%
Managed	75%
Optimized	50%

Table 2 Effectiveness and Risk

Effectiveness	Risk Level	Risk (%)
Extremely Effective	Very Low	1-19
Very Effective	Low	20-39
Moderately Effective	Moderate	40-59
Somewhat Effective	High	60-79
Slightly Effective	Very High	80-100